Evidence and Lessons Learned

FinanceGuard AI Governance and Compliance Portfolio

Purpose

This companion artifact shows what evidence would support the portfolio's control conclusions, how that evidence should be evaluated, and what the team learned from building a traceable executive governance package.

Sample Evidence Register

Evidence ID	Sample artifact	Linked requirement	Evaluation notes	Current result
EV-01	Approved data inventory and lineage map showing PII sources, transformations, storage locations, subprocessors, and deletion points.	GAP-01; ISO A.5.2; SOC 2 CC7.1	Accept only if scope covers on-premises and cloud flows, owners approve the record, and sampled records reconcile to deletion logs. A policy alone does not prove operation.	**Fail**
EV-02	API gateway configuration export, prompt/response log samples, alert rules, review tickets, and retention settings.	GAP-02; ISO A.6.2	Verify all production endpoints are covered, alerts are actionable, reviews occur at the required cadence, and exceptions generate tracked remediation.	**Partial**
EV-03	AI system impact assessment with privacy, fairness, safety, stakeholder, and regulatory analysis plus approved treatment actions.	GAP-03; ISO A.7.2; Clause 6.1.2	Confirm the assessment matches the deployed use case, identifies affected stakeholders, assigns risk owners, and is approved before expansion.	**Fail**
EV-04	Vulnerability assessment, prompt-injection and adversarial test results, RBAC review, model-weight change log, and closure tickets.	ISO A.8.3; SOC 2 CC6.1 and CC6.3	Testing must cover hybrid-cloud endpoints and model-specific threats. Open high-risk findings or missing retest evidence prevent a Pass.	**Partial**
EV-05	Approved model card, intended-use limits, prohibited uses, human-review criteria, analyst training, and acknowledgements.	GAP-03; ISO A.9.2	Check that limitations are specific, users understand escalation requirements, and training completion is retained for the full authorized population.	**Partial**
EV-06	Steering Committee decision record, exception register, remediation plan, milestone reporting, and written CISO residual-risk acceptance.	RACI; executive decision gate	Evidence must show one decision owner, time-bound conditions, named action owners, closure criteria, and escalation for overdue High risks.	**Required before scaling**

Evidence Evaluation Notes

Relevance: The artifact must directly support the stated control and the deployed FinanceGuard AI use case, not a generic enterprise process.

Completeness: Evidence must cover the hybrid-cloud boundary, PII-bearing workflows, authorized users, production endpoints, and the review period being asserted.

Reliability: Prefer system-generated records, approved configurations, signed assessments, tickets, and test outputs over narrative descriptions or screenshots without provenance.

Operating effectiveness: Design documentation is insufficient by itself. A Pass requires proof that the control operated, was reviewed, produced exceptions, and drove remediation.

Traceability: Each artifact should identify the control, evidence owner, collection date, system/environment, reviewer, result, exception, and linked closure record.

Decision rule: Pass means complete and operating evidence; Partial means control elements exist but coverage, review, or documentation is incomplete; Fail means evidence is absent or the control is fundamentally ineffective.

Project Retrospective

What Worked: Using a single system profile and consistent gap IDs kept the RACI, ISO/IEC 42001 matrix, SOC 2 assessment, and executive recommendation aligned.

Key Challenge: The project required distinguishing between controls that were documented or designed and controls that had sufficient evidence to demonstrate operating effectiveness.

Key Lesson: Audit readiness depends on both strong control design and reliable evidence. Policies alone are not enough without supporting logs, approvals, assessments, testing results, and remediation records.

Risk Insight: PII management, hybrid-cloud monitoring, AI security testing, and impact assessments are interconnected. A weakness in one area can create compliance gaps across multiple governance frameworks.

Improvement Opportunity: Future assessments should define evidence requirements, owners, reviewers, and acceptance criteria at project kickoff rather than during the audit-readiness review.

F**inal Takeaway:** The Conditional Go recommendation balanced business enablement with risk management by allowing bounded use while preventing further scaling until identified high-risk gaps are remediated and residual risk is formally accepted.